ROTEIRO DE ESTUDOS · WINDOWS SERVER 2025 · MÓDULO 04

Group Policy

Como as GPOs são armazenadas, processadas e filtradas; políticas x preferências; Central Store; políticas de senha; diagnóstico e automação

Nível	Intermediário
Carga sugerida	2 semanas (16–20 h)
Pré-requisitos	Módulo 03 concluído (domínio com OUs, usuários e o CLI01 no domínio)
Relação com AZ-802	"Manage Windows Server by using domain-based Group Policies" e "Implement operating system security by using Group Policies"

Objetivos do módulo

- Explicar onde uma GPO é armazenada e como chega até o cliente.
- Prever qual configuração vence quando várias GPOs se aplicam (ordem de processamento, herança, bloqueio e imposição).
- Usar filtros de segurança, filtros WMI e processamento de loopback.
- Diferenciar políticas de preferências e usar segmentação por item.
- Configurar o Central Store de modelos administrativos.
- Aplicar políticas de senha e bloqueio, inclusive políticas refinadas (FGPP).
- Diagnosticar problemas com `gpresult`, modelagem, logs e PowerShell.

1. O que é uma GPO

Uma Group Policy Object (GPO) é um conjunto de configurações que o AD distribui para computadores e usuários. É o principal mecanismo de **configuração centralizada** do Windows: segurança, mapeamentos, software, firewall, atalhos, registro, scripts e muito mais. Cada GPO tem duas metades independentes:

- **Configuração do Computador**: aplicada ao objeto computador, na inicialização e em segundo plano.
- **Configuração do Usuário**: aplicada ao objeto usuário, no logon e em segundo plano.

Uma GPO só faz efeito quando está **vinculada** (linked) a um site, ao domínio ou a uma OU. A mesma GPO pode ter vários vínculos.

1.1 Onde a GPO mora

Parte	Local	Conteúdo
Group Policy Container (GPC)	No banco do AD: `CN=Policies,CN=System,DC=...`	Versão, status, vínculos, filtros WMI; replicado pela replicação do AD

Parte	Local	Conteúdo
Group Policy Template (GPT)	No SYSVOL: `\\corp.lab.internal\SYSVOL\corp.lab.internal\Policies\{GUID}`	Arquivos das configurações (registry.pol, scripts, GptTmpl.inf); replicado pelo DFS-R

> **NOTA**
> Se o GPC e o GPT ficarem com versões diferentes entre DCs (por exemplo, falha no DFS-R), clientes podem receber configurações inconsistentes. Por isso a saúde da replicação (Módulos 03 e 10) afeta diretamente as GPOs.

1.2 GPOs padrão

- **Default Domain Policy**: vinculada ao domínio. É onde ficam as políticas de **senha, bloqueio de conta e Kerberos** das contas de domínio. Essas três políticas só têm efeito para contas de domínio quando definidas em uma GPO vinculada **no nível do domínio**.
- **Default Domain Controllers Policy**: vinculada à OU Domain Controllers; define direitos de usuário e auditoria dos DCs.

> **DICA**
> Não use as GPOs padrão para outras configurações. Crie GPOs novas, com nomes descritivos (ex.: `SEC - Estacoes - Firewall`, `USR - Financeiro - Mapeamentos`). Assim fica fácil saber o que cada uma faz e reverter mudanças.

2. Ordem de processamento (LSDOU)

As GPOs são aplicadas nesta ordem. Em caso de conflito na mesma configuração, **vence a última aplicada**:

1. **L**ocal: a política local do próprio computador.
2. **S**ite: GPOs vinculadas ao site AD do computador.
3. **D**omínio: GPOs vinculadas ao domínio.
4. **O**U: GPOs vinculadas às OUs, da mais alta (pai) para a mais baixa (onde o objeto está).

Dentro de um mesmo contêiner, a **ordem de vínculo** (link order) decide: o vínculo com número **1** tem a maior precedência (é aplicado por último).

2.1 Alterando a herança

Mecanismo	Onde se aplica	Efeito
Bloquear herança (Block Inheritance)	Na OU	A OU ignora GPOs vinculadas acima dela
Imposta (Enforced)	No vínculo da GPO	A GPO não pode ser bloqueada abaixo e vence conflitos com GPOs de níveis inferiores
Desabilitar vínculo	No vínculo	O vínculo deixa de valer, sem apagar a GPO
Desabilitar metade da GPO	Na GPO	Ignora a parte de Computador ou de Usuário (acelera o processamento)

> **ATENÇÃO**
>
> "Enforced" vence "Block Inheritance". Use os dois com moderação: muitas exceções tornam o resultado imprevisível e difícil de auditar. A estratégia mais saudável é ter uma boa estrutura de OUs e poucas exceções.

3. Filtragem

3.1 Filtro de segurança

Por padrão, a GPO se aplica a **Authenticated Users** (o que inclui computadores). Para aplicá-la só a um grupo, remova Authenticated Users do campo *Security Filtering* e adicione o grupo desejado.

> **ATENÇÃO**
>
> Desde a atualização de segurança MS16-072, o **computador** precisa ter permissão de leitura na GPO, mesmo nas de usuário. Ao remover Authenticated Users do filtro, mantenha a permissão **Read** (sem *Apply*) para Authenticated Users ou Domain Computers na aba Delegation. Esquecer isso é a causa mais comum de "a GPO de usuário parou de funcionar".

3.2 Filtro WMI

Aplica a GPO apenas se uma consulta WMI retornar verdadeiro no cliente. É avaliado no cliente, então use com parcimônia (custa tempo de processamento).

```
-- Só servidores (ProductType 3) com Windows Server 2025 (build 26100)
SELECT * FROM Win32_OperatingSystem WHERE ProductType = "3" AND BuildNumber = "26100"

-- Só notebooks (com bateria)
SELECT * FROM Win32_Battery
```

3.3 Processamento de loopback

Normalmente, as configurações de usuário vêm da OU onde o **usuário** está. Com loopback, elas passam a depender da OU do **computador**. Caso clássico: servidores RDS ou quiosques, em que qualquer usuário deve receber a mesma configuração restrita.

- **Merge**: aplica as GPOs de usuário normais e depois as da OU do computador (estas vencem conflitos).
- **Replace**: ignora as GPOs de usuário normais e usa apenas as da OU do computador.

Configuração: `Configuração do Computador > Políticas > Modelos Administrativos > Sistema > Política de Grupo > Configurar o modo de processamento de loopback da política de grupo do usuário`.

4. Políticas x Preferências

Aspecto	Políticas (Policies)	Preferências (Preferences)
Comportamento	Impõem e travam a configuração (o usuário não muda)	Definem um valor inicial; o usuário pode alterar, e a preferência pode reaplicar no próximo ciclo
Ao remover a GPO	Configurações de Modelos Administrativos são revertidas	Itens ficam no sistema ("tatuagem"), salvo se marcada a opção de remover quando não se aplicar mais

Aspecto	Políticas (Policies)	Preferências (Preferences)
Exemplos	Senha, auditoria, firewall, restrições de interface	Mapear unidades, impressoras, atalhos, chaves de registro, tarefas agendadas, usuários e grupos locais
Segmentação	Só por vínculo e filtros	**Segmentação por item** (Item-Level Targeting): grupo, OU, IP, SO, nome do computador, etc.

SEGURANÇA

Nunca grave senhas em preferências. A antiga opção de definir senha em preferências (cpassword) foi bloqueada pela atualização MS14-025 porque a chave de criptografia era pública. Para senhas de administradores locais, use o **Windows LAPS** (Módulo 08).

5. Modelos administrativos e Central Store

As configurações de "Modelos Administrativos" vêm de arquivos **ADMX** (definição) e **ADML** (texto no idioma). Por padrão, o editor usa os modelos da máquina onde você está editando, o que gera inconsistências entre administradores. O **Central Store** resolve isso: uma pasta única no SYSVOL usada por todos.

```
# Criar o Central Store copiando os modelos de uma máquina atualizada (ex.: Windows 11 ou Server
    ↪ 2025)
$cs = "\\corp.lab.internal\SYSVOL\corp.lab.internal\Policies\PolicyDefinitions"
New-Item -ItemType Directory -Path $cs -Force
Copy-Item C:\Windows\PolicyDefinitions\*.admx $cs
Copy-Item C:\Windows\PolicyDefinitions\pt-BR $cs -Recurse
Copy-Item C:\Windows\PolicyDefinitions\en-US $cs -Recurse
```

Modelos de outros produtos (Microsoft Edge, Office, Google Chrome) são baixados dos fabricantes e copiados para o mesmo lugar. Quando o editor de GPO mostra "Definições de política (arquivos ADMX) recuperadas do repositório central", deu certo.

6. Políticas de senha e bloqueio

Configuração	Onde	Observação
Comprimento mínimo, histórico, idade máxima e mínima, complexidade	Default Domain Policy > Configuração do Computador > Políticas > Configurações do Windows > Configurações de Segurança > Políticas de Conta	Valem para todas as contas do domínio
Limite de bloqueio, duração, zerar contador	Mesmo local, "Política de Bloqueio de Conta"	Equilíbrio entre proteção contra força bruta e risco de negação de serviço
Políticas refinadas (FGPP)	Objetos PSO no contêiner Password Settings Container	Aplicadas a usuários ou grupos globais, não a OUs

```
Get-ADDefaultDomainPasswordPolicy

# Política mais forte para administradores (FGPP)
New-ADFineGrainedPasswordPolicy -Name "PSO-Admins" -Precedence 10 `
    -MinPasswordLength 16 -ComplexityEnabled $true -PasswordHistoryCount 24 `
    -MaxPasswordAge 180.00:00:00 -LockoutThreshold 5 -LockoutDuration 00:30:00 `
    -LockoutObservationWindow 00:30:00 -ReversibleEncryptionEnabled $false
Add-ADFineGrainedPasswordPolicySubject "PSO-Admins" -Subjects "GG-Admins-TI"
Get-ADUserResultantPasswordPolicy ana.souza
```

DICA

Para bloquear senhas fracas e variações do nome da empresa, a Microsoft oferece o **Microsoft Entra Password Protection para AD DS** (agente nos DCs com lista global de senhas proibidas e lista personalizada). Ele está no escopo do AZ-802 e é tratado no Módulo 08.

7. Atualização das políticas no cliente

- Estações e servidores membros reprocessam as GPOs em segundo plano a cada **90 minutos**, com variação aleatória de até 30 minutos. Controladores de domínio, a cada **5 minutos**.
- Algumas configurações só valem na inicialização ou no logon (instalação de software, redirecionamento de pastas, algumas configurações de segurança).
- Por padrão, só arquivos alterados são reaplicados; configurações de segurança são reaplicadas a cada 16 horas mesmo sem mudança.

```
gpupdate /force                                  # no cliente
Invoke-GPUpdate -Computer CLI01 -Force -RandomDelayInMinutes 0   # remoto, a partir do DC
```

8. Administrar GPOs com PowerShell

```
Import-Module GroupPolicy
New-GPO -Name "SEC - Estacoes - Bloqueio de tela" -Comment "Bloqueia a tela após 10 min"
New-GPLink -Name "SEC - Estacoes - Bloqueio de tela" -Target
    ↪ "OU=Estacoes,OU=Computadores,DC=corp,DC=lab,DC=internal"

# Configuração baseada em registro (Modelos Administrativos)
Set-GPRegistryValue -Name "SEC - Estacoes - Bloqueio de tela" `
    -Key "HKLM\Software\Microsoft\Windows\CurrentVersion\Policies\System" `
    -ValueName InactivityTimeoutSecs -Type DWord -Value 600

Get-GPO -All | Sort-Object ModificationTime -Descending | Select-Object -First 10 DisplayName,
    ↪ ModificationTime
Get-GPInheritance -Target "OU=Estacoes,OU=Computadores,DC=corp,DC=lab,DC=internal"
Get-GPOReport -Name "SEC - Estacoes - Bloqueio de tela" -ReportType Html -Path .\gpo.html

# Backup e restauração (faça antes de qualquer mudança grande)
Backup-GPO -All -Path \\SRV01\Backups\GPO
Restore-GPO -Name "SEC - Estacoes - Bloqueio de tela" -Path \\SRV01\Backups\GPO
```

9. Diagnóstico

Ferramenta	Para quê
`gpresult /r`	Resumo das GPOs aplicadas e filtradas (e por qual motivo) para o usuário e o computador atuais
`gpresult /h relatorio.html`	Relatório completo com o valor vencedor de cada configuração
`Get-GPResultantSetOfPolicy`	O mesmo via PowerShell, inclusive para outro computador/usuário
Group Policy Results (GPMC)	RSoP remoto de uma combinação usuário + computador
Group Policy Modeling (GPMC)	Simula "e se" este usuário entrar naquela máquina daquela OU
Log `Microsoft-Windows-GroupPolicy/Operational`	Linha do tempo detalhada do processamento no cliente

```
gpresult /scope computer /v
Get-WinEvent -LogName Microsoft-Windows-GroupPolicy/Operational -MaxEvents 30 |
    Select-Object TimeCreated, Id, Message
```

Roteiro rápido quando "a GPO não aplicou":

1. A GPO está **vinculada** à OU certa e o vínculo está habilitado?
2. O objeto (usuário ou computador) está mesmo nessa OU? Lembre: configurações de **usuário** seguem o usuário; de **computador**, o computador.
3. Há **bloqueio de herança**, outra GPO com precedência maior ou uma Enforced em conflito?
4. O **filtro de segurança** inclui o objeto? O computador tem Read (MS16-072)?
5. O **filtro WMI** retorna verdadeiro naquele cliente?
6. O cliente **alcança um DC** e o SYSVOL? (DNS, rede, `nltest /dsgetdc:corp.lab.internal`)
7. A configuração exige **reinício ou novo logon**?
8. A **replicação** de SYSVOL e AD está saudável entre os DCs?

10. Linhas de base de segurança

A Microsoft publica linhas de base de segurança (security baselines) com configurações recomendadas por versão do Windows. Há dois caminhos oficiais:

- **Security Compliance Toolkit (SCT)**: GPOs prontas para importar no domínio (`Import-GPO`) e a ferramenta Policy Analyzer para comparar com o que você já tem.
- **OSConfig** (Windows Server 2025): aplica e mantém a linha de base diretamente no servidor, com correção de desvios. Detalhado no Módulo 08.

Nunca importe uma linha de base direto em produção: aplique numa OU de teste, valide aplicações e só então expanda.

LABORATÓRIO

Laboratório 4.1: GPOs do dia a dia

- Crie o Central Store com modelos pt-BR e en-US.
- Crie uma GPO de usuário para o Financeiro que mapeia `F:` para `\\SRV01\Financeiro` usando **preferência** com segmentação por item (só membros de GG-Financeiro).
- Crie uma GPO de computador para estações: bloqueio de tela em 10 minutos, negar acesso de execução em armazenamento removível e uma regra de firewall de entrada para o WinRM só da sub-rede de administração.
- Crie a FGPP "PSO-Admins" e confirme com `Get-ADUserResultantPasswordPolicy`.
- No CLI01, rode `gpresult /h` e explique cada GPO aplicada e filtrada.

LABORATÓRIO

Laboratório 4.2: quebre e conserte

- Remova Authenticated Users do filtro de segurança da GPO de mapeamento sem dar Read aos computadores. Observe o resultado no `gpresult` e corrija.
- Bloqueie a herança na OU Estacoes e depois marque uma GPO do domínio como Enforced. Qual venceu? Por quê?
- Use o Group Policy Modeling para prever o resultado antes de aplicar uma mudança.

Checklist de revisão

- Onde ficam o GPC e o GPT? Como cada um é replicado?
- Explique LSDOU e a ordem de vínculo. Qual GPO vence um conflito?
- Qual a diferença entre Block Inheritance e Enforced? Quem vence?
- O que mudou com a MS16-072 e como isso afeta o filtro de segurança?
- Quando usar loopback merge e quando usar replace?
- Por que nunca guardar senhas em preferências de GPO?
- Onde as políticas de senha do domínio precisam estar vinculadas? O que é uma FGPP?
- Liste os passos para diagnosticar uma GPO que não aplicou.

Referências oficiais

› Visão geral de Group Policy no Windows Server
https://learn.microsoft.com/en-us/windows-server/identity/ad-ds/manage/group-policy/group-policy-overview

› Criar e gerenciar o Central Store de modelos administrativos
https://learn.microsoft.com/en-us/troubleshoot/windows-client/group-policy/create-and-manage-central-store

› Módulo PowerShell GroupPolicy
https://learn.microsoft.com/en-us/powershell/module/grouppolicy

› Políticas de senha refinadas (FGPP)
https://learn.microsoft.com/en-us/windows-server/identity/ad-ds/get-started/adac/fine-grained-password-policies

› Microsoft Security Compliance Toolkit
https://learn.microsoft.com/en-us/windows/security/operating-system-security/device-management/windows-security-configuration-framework/security-compliance-toolkit-10

› Novidades do Windows Server 2025 (OSConfig e linha de base)
https://learn.microsoft.com/en-us/windows-server/get-started/whats-new-windows-server-2025